

Guía Metodológica de la Encuesta MITRE ATT&CK

1. Propósito

Esta guía explica cómo aplicar, interpretar y explotar la Encuesta Integral de Madurez MITRE ATT&CK.
[web:3][web:29][web:66]

Se orienta a responsables de ciberseguridad que quieran pasar de “tenemos un SIEM” a “tenemos un sistema de detección razonablemente civilizado y medible”.

2. Alcance y público objetivo

- **Ámbito organizativo:** cualquier entidad con activos digitales significativos, especialmente sectores críticos y administraciones públicas, alineadas con prácticas europeas (ENISA Threat Landscape) y evaluaciones MITRE ATT&CK Enterprise.[web:66][web:43][web:16][web:22]
- **Roles destinatarios:** CISO, responsables de SOC, CTI, respuesta a incidentes, riesgos y dirección de TI.

3. Estructura de la encuesta

La encuesta se articula en bloques:

1. Datos generales.
2. Gobierno y estrategia.
3. Cobertura de tácticas y técnicas.
4. Calidad de detección.
5. Métricas temporales.
6. Amenazas/CTI.
7. Integración con herramientas.
8. Ejercicios y mejora.
9. Indicadores económicos (IGM, ROI).
10. Cultura y competencias.

Cada bloque se construye sobre la base de:

- Cobertura ATT&CK y calidad de detección, alineadas con los criterios de las evaluaciones MITRE 2025 (cobertura de técnicas, capacidad de protección, falsos positivos, detección temprana, cloud, identidad).[web:16][web:22][web:64][web:62][web:65]
- Mapeo de amenazas sectoriales y europeas, siguiendo los enfoques de ENISA para categorizar TTP.[web:66][web:43]

4. Escala de madurez

4.1 Justificación

La escala 0-5 está inspirada en modelos de madurez y en los niveles de adopción práctica observados en organizaciones que integran ATT&CK como “tejido conectivo” entre CTI, detección e IR.[web:29]
[web:66]

- 0: No aplica / sin relevancia.
- 1: No implementado.
- 2: Inicial/ad-hoc.
- 3: Definido.
- 4: Gestionado/medido.
- 5: Optimizado.

Esta granularidad permite:

- Comparar unidades internas (p. ej., SOC corporativo vs. SOC OT).
- Medir progreso interanual (antes/después de proyectos).
- Alimentar indicadores agregados (IGM).

5. Proceso de aplicación

5.1 Preparación

- Identificar participantes: CISO, responsables de SOC, CTI, IR, negocio crítico.
- Compartir la encuesta con antelación explicando propósito (no es un juicio sumarásimos).
- Acordar si las respuestas se consolidan en una única visión o se distinguen por unidad/país.

5.2 Recogida de información

- Responder preferentemente de forma colectiva (workshop de 2–3 horas).
- Para preguntas con potencial controversia (“¿tenemos esto realmente?”), pedir evidencias mínimas: documento, procedimiento, dashboard, informe de ejercicios.
- Registrar comentarios cualitativos para enriquecer la interpretación.

5.3 Validación

- Contrastar la autoevaluación con datos objetivos cuando existan:
- Resultados de evaluaciones MITRE-style de proveedores.[web:16][web:22][web:59]
- Informes de ejercicios de red teaming/purple teaming.[web:16][web:22]
- Dashboards de cobertura ATT&CK.[web:23]

6. Cálculo del Índice Global de Madurez (IGM)

6.1 Definición

El IGM es una media ponderada de varios bloques:

- Gobierno y estrategia (G).
- Cobertura de tácticas y técnicas (C).
- Calidad de detección (Q).
- Métricas temporales (T).
- Amenazas/CTI (A).
- Integración y procesos (I).
- Ejercicios y mejora (E).
- Economía y ROI (F).
- Cultura y competencias (H).

Cada pregunta se valora de 0 a 5.

Para cada bloque se calcula:

$$\left[\text{IGM_Bloque} = \frac{\sum \text{Puntuaciones_preguntas}}{\text{Número_de_preguntas}} \right]$$

El IGM global se puede calcular con pesos:

$$\left[\text{IGM_Global} = \sum (\text{IGM_Bloque} \times \text{Peso_Bloque}) \right]$$

Ejemplo de pesos recomendados (flexibles):

- G: 15 %
- C: 20 %
- Q: 15 %
- T: 10 %
- A: 10 %
- I: 10 %
- E: 10 %
- F: 5 %
- H: 5 %

7. Uso del ROI

La guía propone:

11. Estimar el riesgo base (pérdida anual esperada) a partir de datos sectoriales (p. ej. ENISA, informes industriales).[web:66][web:61]
12. Asociar mejoras de IGM con reducciones plausibles de probabilidad/impacto (p. ej., al mejorar detección temprana en tácticas de credenciales y movimiento lateral, se reduce probabilidad de incidentes mayores).[web:66][web:26]
13. Calcular ROI aproximado:

$$\left[\begin{array}{l} \text{ROI} = \frac{\text{Reducción_de_Riesgo_Esperado} - \text{Coste_Iniciativa}}{\text{Coste_Iniciativa}} \end{array} \right]$$

8. Interpretación de resultados

- $IGM < 2$: adopción embrionaria; ATT&CK vive, si acaso, en presentaciones.
- $2 \leq IGM < 3$: organización en transición hacia un uso estructurado.
- $3 \leq IGM < 4$: ATT&CK integrado en SOC/IR, con métricas emergentes.
- $4 \leq IGM < 4,5$: organización madura, con buena visibilidad y mejora continua.
- $\geq 4,5$: referencia avanzada; probablemente su SOC se sabe la matriz de memoria, para bien y para mal.

Recomendación: acompañar el IGM de narrativas y gráficos que muestren:

- Tácticas más débiles.
- Técnicas críticas sin cobertura.
- Brechas entre cobertura declarada y validada.
- Evolución temporal del IGM.

9. Limitaciones y buenas prácticas

- La encuesta es auto-declarativa; el sesgo de optimismo es un clásico.
- Es recomendable complementarla con ejercicios prácticos, resultados de evaluaciones y análisis de incidentes.[web:16][web:22][web:66]
- MITRE ATT&CK no es un estándar normativo, sino una base de conocimiento; conviene integrarlo con marcos de gestión de riesgo (NIST CSF, ISO 27001, ENS, DORA, etc.) y con las amenazas sectoriales europeas.[web:66][web:52]